

Security+ 2.3 · OS Vulnerabilities

Master CyberSec — Official CompTIA Security+ (SY0-701) Comprehensive Study Guide · **Lesson 2.3 — OS Vulnerabilities (4:09)** · [Official YouTube Video ↗](#) · [Professor Messer Study Hub ↗](#)

Executive Lesson Summary: Operating system vulnerabilities arise from flaws in the kernel, services, or libraries. Microsoft releases patches on Patch Tuesday, addressing dozens of CVEs monthly. Unpatched OSes are easy targets. Zero-day OS vulnerabilities have no available fix. Defenses include prompt patching and endpoint detection and response (EDR).

High-Yield Core Concepts Tested on Exam

- Patch Tuesday: Microsoft releases dozens of CVE fixes monthly
- Legacy OS (e.g., Windows XP): unsupported, no patches—isolate or decommission
- Zero-day: no patch available, requires mitigation
- Defense: patch ASAP, use EDR, segment legacy systems

Exam Tips & Classic Scenarios

- 'operating system lacks patches' = legacy/unsupported OS vulnerability
- 'no fix available for OS flaw' = zero-day

Typical Exam Scenario: Windows XP remains on an industrial network because critical software does not run on modern OSes, creating a legacy OS risk.

Beyond the Video: Official CompTIA Exam Concepts, Protocols & Traps (Lesson 2.3 — OS Vulnerabilities)

Why is this advanced coverage required for SY0-701? Video overviews provide foundational familiarity, but CompTIA tests practical engineering judgment and requires deep familiarity with the following protocols, acronyms, and operational nuances in this domain:

- **CVE:** Common Vulnerabilities and Exposures: Publicly standardized dictionary of known information security vulnerabilities and exposures.

Classic CompTIA Traps & Question Framing:

- Avoid rote memorization: CompTIA exam prompts regularly adjust technical constraints requiring you to defend why one valid security control is the *MOST appropriate* or *FIRST step*.
- Scrutinize question qualifiers: 'without additional licensing costs' favors native OS tools; 'granular administrative command accounting' favors TACACS+ over RADIUS; 'non-repudiation' mandates asymmetric private key signing.

Practice Questions with In-Depth Solutions (10 Questions)

Detailed answer key with step-by-step technical rationale and comprehensive distractor breakdown provided below. Attempt answering independently first.

1. A vulnerability that the manufacturer does not yet know about and has no fix for is called:

- A)** Public CVE
- B)** Zero-day
- C)** Backdoor
- D)** False positive

2. What type of attack exploits vulnerabilities before a patch is available?

- A)** Zero-day attack
- B)** DDoS attack
- C)** Brute force attack
- D)** Man-in-the-Middle attack

3. Corporate scenario (OS Vulnerabilities): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.3), an analyst evaluates the following technical requirement: 'Patch Tuesday: Microsoft fixes dozens of CVEs per month'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Implement the corresponding solution: Patch Tuesday: Microsoft fixes dozens of CVEs per month...
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators with generic credentials

4. Corporate scenario (OS Vulnerabilities): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.3), an analyst evaluates the following technical requirement: 'Legacy (XP): no support, no patch — disable/segment'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Implement the corresponding solution: Legacy (XP): no support, no patch — disable/segment...
- D)** Allow shared access among administrators with generic credentials

5. Corporate scenario (OS Vulnerabilities): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.3), an analyst evaluates the following technical requirement: 'operating system lacks patches' = legacy/unsupported OS vulnerability'. What is the best recommendation or applicable control classification?

- A)** Implement the corresponding solution: 'operating system lacks patches' = legacy/unsupported OS vulnerability...
- B)** Temporarily disable audit logs to accelerate system throughput
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators using generic credentials

6. Corporate scenario (OS Vulnerabilities): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.3), an analyst evaluates the following technical requirement: 'Scenario: Windows XP on the industrial network because critical software does not run on modern OS' = legacy OS risk. What is the best recommendation or applicable control classification?

- A)** Implement the corresponding solution: Scenario: 'Windows XP on the industrial network because critical software does not run on modern OS' = legacy OS risk.
- B)** Temporarily disable audit logs to accelerate system throughput
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators using generic credentials

7. Corporate scenario (OS Vulnerabilities): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.3), an analyst evaluates the following technical requirement: 'Patch Tuesday: Microsoft fixes dozens of CVEs per month.' What is the best recommendation or applicable control classification?

- A)** Implement the corresponding solution: Patch Tuesday: Microsoft fixes dozens of CVEs per month...
- B)** Temporarily disable audit logs to accelerate system throughput
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators using generic credentials

8. Corporate scenario (OS Vulnerabilities): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.3), an analyst evaluates the following technical requirement: 'Legacy (XP): no support, no patch — disable/segment'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Implement the corresponding solution: Legacy (XP): no support, no patch — disable/segment...
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators with generic credentials

9. Corporate scenario (OS Vulnerabilities): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.3), an analyst evaluates the following technical requirement: 'operating system lacks patches' = legacy/unsupported OS vulnerability. What is the best recommendation or applicable control classification?

- A)** Implement the corresponding solution: 'operating system lacks patches' = legacy/unsupported OS vulnerability...
- B)** Temporarily disable audit logs to accelerate system throughput
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators with generic credentials

10. Corporate scenario (OS Vulnerabilities): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.3), an analyst evaluates the following technical requirement: 'Scenario: Windows XP on the industrial network because critical software does not run on modern OS' = legacy OS risk. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to speed up system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Allow shared access among administrators using generic credentials
- D)** Implement the corresponding solution: Scenario: Windows XP on the industrial network because critical software does not run ...

COMPREHENSIVE ANSWER KEY & DISTRACTOR BREAKDOWN

1) B — Zero-day.

✓ **Why it's correct:** The correct answer is 'Zero-day'. A zero-day vulnerability is one that is unknown to the software or hardware vendor at the time of exploitation. Since the manufacturer is unaware of it, no patch is available, making it highly dangerous. The term 'zero-day' refers to the fact that the vendor had 'zero days' to fix the flaw before it was exploited. The question describes exactly this situation: a vulnerability that the manufacturer does not yet know about and has no fix for. Therefore, 'Zero-day' is the exact answer according to the CompTIA syllabus.

✗ **Why the others are wrong:**

- *Public CVE:* CVE (Common Vulnerabilities and Exposures) is a reference system for publicly known vulnerabilities. A public CVE is a vulnerability that has already been disclosed, cataloged, and generally has a fix or known mitigations available. In the question, the vulnerability is unknown to the manufacturer and has no fix, which contradicts the definition of a public CVE. Therefore, this option is incorrect.
- *Backdoor:* A backdoor is an unauthorized access mechanism intentionally inserted into a system, application, or device, often by the developer or an attacker, to bypass normal authentication. Although a backdoor can be exploited without the manufacturer's knowledge, it is not necessarily an unpatched vulnerability; it can be an intentional feature or a malware artifact. The question describes an unknown and unpatched vulnerability, which is the definition of a zero-day, not a backdoor. Therefore, backdoor is not the correct answer.
- *False positive:* A false positive, in the security context, is an incorrect alert generated by detection tools (such as antivirus or IDS) that identify legitimate activity as malicious. It has no relation to unknown vulnerabilities or lack of a fix. The question deals with a real, exploitable vulnerability, not a detection error. Therefore, false positive is completely inadequate.

2) A — Zero-day attack.

✓ **Why it's correct:** The correct answer is 'Zero-day attack'. A zero-day attack exploits a vulnerability that is unknown to the software or hardware vendor, or for which no patch is yet available. The term 'zero-day' refers to the fact that exploitation occurs before the developer has had the opportunity to fix the flaw, or on the same day the vulnerability becomes known. These attacks are particularly dangerous because they cannot be mitigated by antivirus signatures or traditional patches, requiring proactive defenses such as behavioral analysis, sandboxing, and network segmentation. In CompTIA Security+, the zero-day concept is associated with advanced threats and the need for defense-in-depth strategies.

✗ **Why the others are wrong:**

- *DDoS attack:* A DDoS (Distributed Denial of Service) attack aims to overwhelm a service, server, or network with massive traffic from multiple sources, making it unavailable to legitimate users. It does not exploit a specific software vulnerability for which no patch exists; instead, it abuses resource capacity and bandwidth. Although it can be devastating, DDoS does not fit the definition of a zero-day attack, as it does not depend on an unknown and unpatched flaw. Mitigation involves traffic filtering, CDNs, and anti-DDoS services, not patch application.
- *Brute force attack:* A brute force attack attempts to guess credentials (passwords, keys) through exhaustive and repeated attempts, often automated. It exploits weak or predictable passwords, not an unpatched software vulnerability. Although it can be used for initial access, it is not classified as a zero-day attack. Defenses include strong password policies, account lockout, multi-factor authentication, and rate limiting, and do not depend on a specific patch for an unknown flaw.
- *Man-in-the-Middle attack:* A Man-in-the-Middle (MitM) attack occurs when an adversary

positions themselves between two communicating parties, intercepting and possibly altering traffic. It exploits authentication flaws, weak encryption, or insecure configurations (e.g., ARP spoofing, DNS spoofing), but is not defined by exploiting an unpatched vulnerability. MitM can be mitigated with strong encryption, digital certificates, and mutual authentication. It is not to be confused with zero-day, which specifically refers to an unknown and unpatched vulnerability.

3) B — Implement the corresponding solution: Patch Tuesday: Microsoft fixes dozens of CVEs per month....

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.3 (OS Vulnerabilities): Patch Tuesday: Microsoft fixes dozens of CVEs per month. This refers to Microsoft's monthly release of security patches for its operating systems and software, addressing known vulnerabilities. The best practice is to implement a patch management process that includes timely application of these patches to mitigate risks.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting principle and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user behavior, and do not block automated attacks, injections, or runtime malware.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

4) C — Implement the corresponding solution: Legacy (XP): no support, no patch — disable/segment....

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.3 (OS Vulnerabilities): Legacy (XP): no support, no patch — disable/segment.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

5) A — Implement the corresponding solution: 'operating system lacks patches' = legacy/unsupported OS vulnerability....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.3 (OS Vulnerabilities): 'operating system lacks patches' = legacy/unsupported OS vulnerability.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).

- *Replace preventive technical controls with informal terms of adherence*: Informal terms are administrative controls, rely solely on user behavior, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials*: Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

6) A — Implement the corresponding solution: Scenario: 'Windows XP on the industrial network because critical software does not run on modern OS' = legacy OS risk..

The correct answer is to implement the corresponding solution: recognize and mitigate legacy OS risk. According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.3 (OS Vulnerabilities), a legacy OS such as Windows XP on an industrial network represents a significant risk due to missing security patches, unsupported updates, and known exploitable vulnerabilities. The appropriate action is to isolate, compensate, or replace the legacy system. Distractor breakdown: • *Temporarily disable audit logs to accelerate system throughput*: Incorrect. This directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to incident detection and breaks compliance standards (PCI DSS, ISO 27001). • *Replace preventive technical controls with informal terms of adherence*: Incorrect. Informal terms are administrative controls that rely solely on user behavior and do not block automated attacks, injections, or runtime malware. • *Allow shared access among administrators using generic credentials*: Incorrect. This destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

7) A — Implement the corresponding solution: Patch Tuesday: Microsoft fixes dozens of CVEs per month....

✓ **Why it is correct**: According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.3 (OS Vulnerabilities): Patch Tuesday: Microsoft fixes dozens of CVEs per month. Patch Tuesday is Microsoft's scheduled monthly release of security updates, addressing multiple Common Vulnerabilities and Exposures (CVEs). It is a key part of vulnerability and patch management.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput*: Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to incident detection and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence*: Informal terms are administrative controls that rely solely on user conduct and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials*: Destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

8) B — Implement the corresponding solution: Legacy (XP): no support, no patch — disable/segment....

✓ **Why it is correct**: According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.3 (OS Vulnerabilities): Legacy (XP): no support, no patch — disable/segment. Legacy operating systems such as Windows XP no longer receive security updates, leaving known vulnerabilities permanently unpatched. The correct risk mitigation is to disable the system if it is not essential, or isolate it on a segmented network with strict access controls to prevent exploitation and lateral movement.

✗ Why the others are wrong:

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and violates compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls that rely solely on user behavior and do not block automated attacks, injections, or runtime malware.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

9) A — Implement the corresponding solution: 'operating system lacks patches' = legacy/unsupported OS vulnerability....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.3 (OS Vulnerabilities): 'operating system lacks patches' = legacy/unsupported OS vulnerability. Unpatched or end-of-life operating systems are a major vulnerability because they no longer receive security updates, leaving known exploits unmitigated.

✗ Why the others are wrong:

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to incident detection and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

10) D — Implement the corresponding solution: Scenario: Windows XP on the industrial network because critical software does not run

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.3 (OS Vulnerabilities): Scenario: Windows XP on the industrial network because critical software does not run on modern OS = legacy OS risk. Legacy operating systems no longer receive security updates, making them highly vulnerable to exploits. The appropriate control is to implement the corresponding solution, which includes isolating legacy systems, applying compensating controls (e.g., network segmentation, virtual patching, strict access controls), and planning for migration or replacement.

✗ Why the others are wrong:

- *Temporarily disable audit logs to speed up system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to incident detection and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls that rely solely on user behavior and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials:* Destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

